

[TEST-01] Lack of Name Formatting Rules

Status: Fixed

Project: [ALIKOHUB ACADEMY](#)

Labels: Login, register

Priority: Medium

Description The system lacks a character filtering policy for name fields. User can successfully with names such as "user_99!". Firstname/Lastname validation for registration is not restricting character types with digits/symbols with 201 success response in Registration API.

1. Initialize the application services (Gateway and Auth Service).
2. Open a terminal or API client (e.g., Postman/Curl).
3. Send a POST request to the registration endpoint <http://localhost:3006/auth/register>.
4. Provide a JSON payload containing numeric or symbolic characters in the firstname or lastname fields.

Example Payload:

```
{
  "email": "new12@gmail.com",
  "firstname": "User-999!",
  "lastname": "Test!!!",
  "password": "password123"
}
```

5. Execute the request using the following curl command:

```
curl -X POST http://localhost:3006/auth/register \
-H "Content-Type: application/json" \
-d '{"email": "new12@gmail.com", "firstname": "User-999!", "lastname": "Test!!!", "password": "password123"}'
```

6. Observe the response code and body.

Expected Result: The API should return a 400 Bad Request status code with a validation message indicating that name fields must only contain alphabetic characters.

Actual Result: The API returns a 201 Created status code, and the user is successfully registered with the invalid name data stored in the database.

Status:	
Project:	<u>ALIKOHUB ACADEMY</u>

Description	- POST to /auth/academy/switch-role with {"newRole":"ADMIN"} returns HTTP 400 with message "newRole must be one of the following values: " due to invalid DTO validation (SwitchRoleDto using @IsEnum([...])). -Additionally, the gateway/controller flow accepts and forwards ADMIN in other places: the gateway endpoint POST /academy/profile/select-role (see academy-profile.controller.ts) and the academy backend handler MessagePattern({ cmd: 'select_academy_role' }) in user.controller.ts accept role changes without restricting ADMIN, enabling privilege escalation.
--------------------	---

PrettyRawHex

```
POST /auth/academy/switch-role http/1.1
Host: localhost:3009
sec-ch-ua-platform: "Linux"
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQoIjFaG9BdnNlbFlxYjltSlgwTzh3IHkqZmVudHkiOnRlc2lzc28_PyIsImhhcnRucyUiOiJoZWlnbiA5MGIgPyciLCJubGVzbnRpbGljaWwvVVNFUj1sInNoYXR1cyI6IkFDEWRSISImFjYWRLbXB2xlIjoIUVRREVVOVCisImfjYWRLbXB2xlIjoIUVRREVVOVCisImFjYWRLbXB2xlIDtGF0dXMioiIjBQRJVkuLClldmVuDHNSb2xlIjoIUVRVFUIsImV2ZW50eC1NOYXR1cyI6IkdFVElwRSISImhmdICiMTc2OTYyOTA0NCwiZXhwIjoxeDZlNDZlOGEvdGFTSExpcxzxtXj_-15nwIdWxrPj_LoTiSq18F2d6dJvtSE
Referer: http://localhost:4200/
sec-ch-ua: "Google Chrome";v="143", "Chromium";v="143", "Not A(Brand)";v="24"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Content-Type: application/json

{
  "newRole": "ADMIN"
}
```

HTTP/1.1 400 Bad Request
access-control-allow-credentials: true
connection: keep-alive
content-length: 172
content-type: application/json; charset=utf-8
date: Wed, 28 Jan 2026 19:40:37 GMT
etag: W/"ac-ZQG6PaBHCEZZsmGZIqG6jdttHg"
keep-alive: timeout=5
vary: Origin

{x-powered-by: Express Remove x-powered-by:express from the response
x-ratelimit-limit: 10
x-ratelimit-remaining: 6
x-ratelimit-reset: 59}

{"statusCode": 400,
"message": "newRole must be one of the following values: ",
"errors": ["Bad Request"],
"timestamp": "2026-01-28T19:40:37.105Z",
"path": "/auth/academy/switch-role"}
}

3. Alternatively, call gateway **POST /academy/profile/select-role** (or send message pattern `select_academy_role`) with payload `{ userId: <id>, role: "ADMIN" }` and observe backend accepts and writes ADMIN to academy profile.

```
silver@silvermist ~/D/U/alikohub-v2-frontend (integrate-upstream-frontend)> curl -i -X POST http://localhost:3009/academy/profile/select-role -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiJFaG9BdmNlbF1xYjltSlgtSThiYXJGQjZNYW0yIiwiaWQiOiJlbnVhbnR1Y2h0dGF0dXMiOjIjQ1RJVkUiLCJ1dmVudHNSb2x1Ijo1VWVNFU1IsImV2Zw50c1N0YXR1cyI6IkFDVE1wRSIsIm1hdCI6MTc2OTY1NDc1NSwiZXhwIjoxNzY5NjU4MzU1fQ.8oL03adpoRQxdfrMyJTzF-fjD26DfC0Ccgib82K3tRs" -H "Content-Type: application/json" -d '{"role": "ADMIN"}'
```

HTTP/1.1 201 Created
X-Powered-By: Express
Vary: Origin
Access-Control-Allow-Credentials: true
X-RateLimit-Limit: 10
X-RateLimit-Remaining: 8
X-RateLimit-Reset: 32
Content-Type: application/json; charset=utf-8
Content-Length: 233
ETag: W/"e9-F97Exrs9181MzArkajgD102duHE"
Date: Thu, 29 Jan 2026 02:47:21 GMT
Connection: keep-alive
Keep-Alive: timeout=5

```
{ "id": 37, "userId": "EhoAvselyqb9mJX00xbarF8Gmam2", "role": "ADMIN", "hasSelectedRole": true, "bio": null, "expertise": [], "specialization": null, "certifications": [], "createdAt": "2026-01-28T16:54:27.245Z", "updatedAt": "2026-01-29T02:47:21.531Z" }
```

Actual:

- POST /auth/academy/switch-role returns 400: `{"statusCode":400,"message":"newRole must be one of the following values: ", "error":"Bad Request"}`.
- The gateway/controller path (`academy-profile.controller.ts` → `academy user.controller.ts`) will accept and persist ADMIN role changes when called, because there is no privilege check.

Expected:

- It should display the role either STUDENT or INSTRUCTOR(no TEACHER).
- The API should reject attempts to set ADMIN via the public role-switch endpoints unless performed by an existing global ADMIN through an admin-only flow.

Fix:

- Replace the broken `@IsEnum(['student','teacher','instructor'])` with a proper validator (e.g., `@IsIn(['student','instructor'])`) or define a TypeScript enum
- Normalize incoming role strings (lowercase) before validation/mapping.
- **Controller / gateway guard:**
In `academy-profile.controller.ts` and `user.controller.ts` require that the caller identity matches target `userId` and deny ADMIN unless `req.user.globalRole === 'ADMIN'`.

Behavior / UI:

Map and display roles as STUDENT or INSTRUCTOR only for user-facing flows; prevent UI flow that attempts to set ADMIN.

[TEST-03] NotFound button not redirecting + missing /admin/settings route

Status:

Project:

[ALIKOHUB ACADEMY](#)

Labels:

Select-Role

Priority:

Medium

Description

Navigating to /admin/settings shows the NotFound page instead of Settings. The Admin sidebar shows a Settings item (/admin/settings) in AdminLayout.tsx but no corresponding route is defined in App.tsx. The NotFound page component NotFoundState.tsx renders a "Go to Dashboard" button that calls an optional onGoHome prop; several callers render NotFoundState without providing onGoHome, so the button is inert.

Steps To Reproduce

1. Go to /admin/settings in browser (authenticated as admin).
2. Observe NotFound page and click "Go to Dashboard" button.

Actual:

Page shows "Page Not Found" and clicking "Go to Dashboard" does nothing (button has no handler).

Admin nav shows Settings but route missing; App routes under /admin only include index, teacher-applications, and courses.

Expected:

Navigating to /admin/settings should load the Settings page.

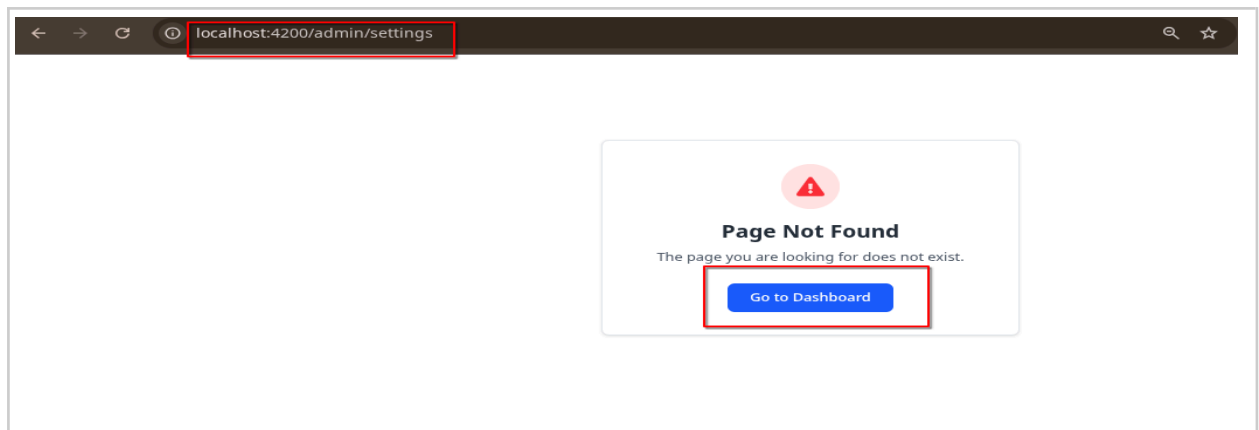
"Go to Dashboard" button on NotFound should navigate back to the appropriate dashboard (e.g., /admin or /dashboard) when clicked.

Fix:

- Add the missing admin route: in App.tsx add a child route under the /admin tree:
`<Route path="settings" element={<SettingsPage/>} />`
(keeps nav and routing consistent with AdminLayout.)

- Make NotFound button functional:

Option A (global default — quick): update NotFoundState.tsx to use `useNavigate()` and fallback to navigate to /admin (or /dashboard)



[TEST-04] Admin can approve/reject instructor applications without seeing applicant data or providing review notes

Status:	Fixed
Project:	ALIKOHUB ACADEMY

Labels:	Admin	Priority:	High
---------	-------	-----------	------

Description	The admin UI (TeacherApplicationsDashboard) displays a list of instructor (teacher) applications with Approve/Reject buttons but does not show application formData (resume, interview responses, documents) or collect required reviewNotes. The backend implemented reviewedBy and reviewNotes for final actions and refuses approval if the application lacks a resume (formData.resumeUrl). This causes blind clicks to fail (400) and risks accidental or uninformed approvals.

1. As admin, open Admin → Teacher Applications (UI).
2. Click Approve on any PENDING application without opening details or entering notes.
3. Observe error in gateway logs and response: 400 "Review notes are required for approval" (or "Cannot approve application without a resume" if resume missing).

Expected Result:

Admin must be able to view full application details (personal details, resume link, documents, interview answers) before approving/rejecting. The approval flow should require and collect non-empty reviewNotes and include reviewer identity; once provided, backend accepts the request and updates status.

Actual Result:

Admin list shows name/email/date/status and Approve/Reject buttons only. Clicking Approve/Reject may return 400 from backend because reviewNotes or reviewedBy were not included, or approval is blocked if resumeUrl is missing.

Impact

- UX: Admins act "blind" to perform Accept or Reject application without seeing the instructor application form
- Missing reviewer notes reduce auditability.

Verification steps:

Open an application → view resume & answers → d,enter review notes → Approve → expect 200 and status updated to APPROVED.

Try Approve without notes → expect client-side validation blocked or backend 400 with message shown to admin.

The screenshot displays the 'Teacher Applications' section of an admin interface. On the left is a blue sidebar with navigation options: 'Admin Panel', 'Dashboard', 'Teacher Applications' (selected), 'Manage Courses', and 'Settings'. The main content area has a title 'Teacher Applications' and a 'Logout' button. Below the title is a search bar and a 'Filter by Status' dropdown set to 'All Statuses'. A table titled 'Applications List' shows 3 of 3 applications. The table has columns: APPLICANT, EMAIL, APPLIED FOR, APPLICATION DATE, STATUS, and ACTIONS. The first application is 'APPROVED' with 'Action completed'. The second application is 'PENDING' and has 'Approve' and 'Reject' buttons. The third application is 'APPROVED' with 'Action completed'.

```
[ApiGateway] 19252 1/29/2026, 7:05:27 AM ERROR [AuthController] Approve Teacher failed: - {
  stack: [
    {
      statusCode: 400,
      message: 'Review notes are required for approval',
      error: 'Bad Request'
    }
  ]
} +1s
[ApiGateway] 19252 1/29/2026, 7:05:27 AM ERROR [GlobalExceptionHandler] POST /auth/academy/approve-teacher/4 - 400 - Review notes are required for approval - { stack: [ null ] } +1ms
```

